

MGM Resorts Ransomware Attack

CASE STUDY · SEPTEMBER 2023

How a single phone call to an IT helpdesk brought down one of the world's largest casino and hospitality empires — and what it reveals about the catastrophic cost of personnel security failure.



11 September 2023: Everything Stops

In the early hours of 11 September 2023, MGM Resorts International began experiencing cascading operational failure across its Las Vegas properties and beyond. The scale of disruption was immediate and total.



Slot Machines

Gaming floors went dark. Machines across MGM Grand, Bellagio, Aria, and Mandalay Bay went offline simultaneously.



Hotel Operations

Room key cards stopped working. Check-in reverted to manual, paper-based processes. Phone systems were impacted.



Financial Systems

Restaurant point-of-sale systems failed. ATMs on MGM properties stopped dispensing cash. Digital signage went dark.



Scope of Impact

Disruption spread beyond Las Vegas to all major MGM-branded properties nationwide, affecting hundreds of thousands of guests.

THE ENTRY VECTOR

One Phone Call. 36 Hours. Total Compromise.

"All ALPHV ransomware group did to compromise MGM Resorts was hop on LinkedIn, find an employee, then call the Help Desk."

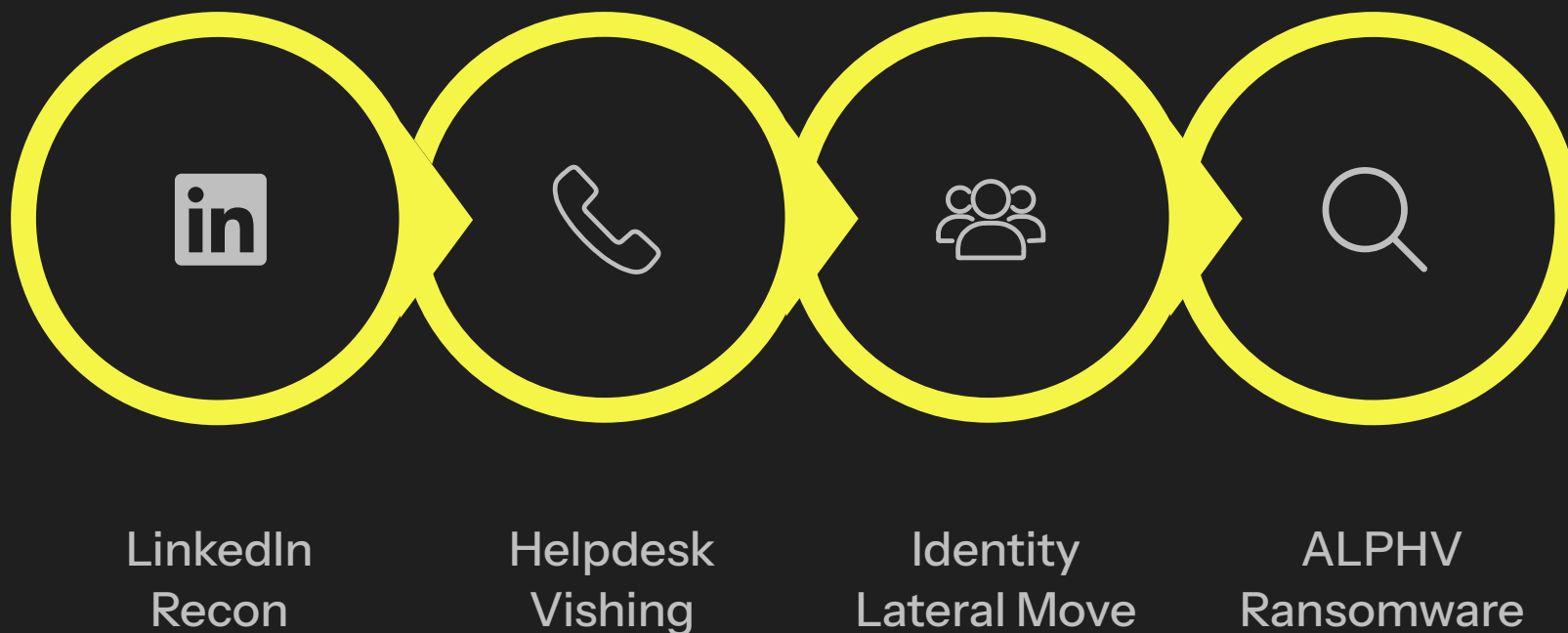
— vx-underground research collective, September 2023

Within days of the attack becoming public, security researchers confirmed the initial access vector with notable accuracy. The entry point was not a zero-day exploit or sophisticated technical breach. It was a phone call — a vishing attack against an IT helpdesk operator who followed standard procedure but applied inadequate identity verification. The attacker claimed to be locked out and requested an MFA reset. The request was granted.



The Four-Step Attack Chain

From open-source intelligence to ransomware deployment, the entire kill chain required no advanced technical capability at the entry stage — only social engineering and patience.



Total elapsed time from the helpdesk call to widespread operational disruption: approximately **36 hours**. The attacker moved from a single compromised identity to domain administrator access, environment mapping, and estate-wide ransomware deployment faster than most organisations can convene an incident response team.

Step-by-Step: How the Attack Unfolded

1

Open-Source Reconnaissance

The attacker identified a specific MGM Resorts employee via LinkedIn, gathering information about their role, reporting manager, IT support arrangements, and likely helpdesk interaction patterns. No hacking was required — all information was publicly available.

2

Helpdesk Social Engineering

The attacker called the MGM IT helpdesk, impersonated the identified employee, established credibility using reconnaissance data, claimed an account lockout, and requested an MFA reset. The helpdesk operator, following standard procedure, reset MFA with the attacker's device registered as the new factor.

3

Identity-Based Lateral Movement

Armed with valid credentials and freshly registered MFA, the attacker accessed enterprise systems. Standard privilege escalation and lateral movement followed. Within hours, the attackers achieved domain administrator privileges and had mapped the environment.

4

Ransomware Deployment

ALPHV/BlackCat ransomware was deployed across the MGM estate. Operational disruption began almost immediately. Ransom negotiations, public communications, and regulatory disclosures followed in rapid succession.

The Threat Actor: Scattered Spider

Also Known As

- **UNC3944** — Mandiant tracking designation
- **Octo Tempest** — Microsoft tracking designation
- **Scattered Spider** — industry common name

Affiliations

- ALPHV/BlackCat ransomware (MGM, Caesars)
- Qilin ransomware (subsequent campaigns)

Profile

Scattered Spider is an English-speaking, financially-motivated threat group. Members are reportedly young — some in their teens and early twenties — based predominantly in English-speaking countries. Their distinguishing capability is not technical sophistication at entry; it is social engineering fluency combined with deep knowledge of corporate IT support procedures.

Sectors Targeted

Hospitality, telecommunications, technology, financial services. The group has demonstrated **repeatable, scalable success** against IT helpdesk and identity infrastructure across multiple major organisations.

PARALLEL CASE

Caesars Entertainment: The Same Attack, A Different Choice

Approximately one week before the MGM disruption became public, **Caesars Entertainment** had been compromised by the same threat actor using the same social engineering pattern. The contrast in outcomes is instructive.

Caesars — Paid the Ransom

Paid approximately **US\$15 million** in ransom. Disclosure came via a routine 10-K SEC filing rather than through visible operational disruption. Normal operations resumed rapidly with minimal guest-facing impact.

MGM — Refused to Pay

Publicly declined to pay the ransom. Suffered approximately **10 days** of major operational disruption before primary systems were substantially restored. Full recovery took considerably longer.

- ① Both outcomes carry long-term costs — financial, reputational, and regulatory. Paying ransom does not guarantee data non-disclosure, and establishes the organisation as a viable target for repeat attacks.

The Financial and Legal Reckoning

MGM Resorts' decision not to pay produced the most visible and quantifiable damage. But the full cost picture extends well beyond the 10-day recovery window.

\$100M+

Direct Revenue Loss

Estimated lost revenue from operational disruption across gaming, hotel, and hospitality operations during the recovery period.

10

Days to Partial Recovery

Primary operations returned to substantially normal state approximately 10 days post-attack. Full system recovery took considerably longer.

\$15M

Caesars Ransom Paid

Caesars Entertainment paid approximately US\$15 million — a fraction of MGM's disruption costs, but a direct reward to the threat actor.

Beyond direct costs: MGM faced SEC disclosure obligations, multi-state customer PII notification requirements, class action litigation exposure, and ongoing regulatory engagement. Legal proceedings continue at time of writing.

Personnel Security Failure Map

The MGM case is a textbook illustration of cascading personnel security control failure. Every control that should have intercepted the attack chain failed to activate. Each failure point maps directly to identifiable policy and training gaps.

Helpdesk Vishing Recognition

The IT helpdesk operator was inadequately trained to identify sophisticated vishing patterns. The attacker's call was fluent, contextually accurate, and consistent with a plausible employee scenario. Training had not prepared staff for this threat profile.

Caller Identity Verification

The caller verification procedure was inadequate. Verification relied on information an attacker could plausibly have gathered through open-source reconnaissance. No out-of-band confirmation mechanism was applied before proceeding with a high-risk action.

MFA Reset Policy

The MFA reset procedure permitted reset on voice authentication alone — a critical control failure. Resetting MFA registers a new authentication device, effectively handing over account access. This action required a higher verification threshold than was applied.

Data Classification and PII Exposure

The breach exposed customer PII including names, contact details, and dates of birth, triggering obligations under multiple US state and federal notification frameworks, SEC disclosure rules, and class action liability. Data access was not adequately restricted to limit blast radius.

Key Lessons for Security Leaders

The MGM Resorts attack is over-determined as a personnel security case study. The technical sophistication of the ransomware payload is largely irrelevant — the decisive failures occurred before any malware was executed.



Treat Helpdesk as a Critical Attack Surface

IT helpdesks are identity control points. MFA resets and credential changes require mandatory out-of-band verification — phone calls alone are insufficient.



Train for Vishing, Not Just Phishing

Social engineering via voice call is a primary threat vector for Scattered Spider-profile groups. Helpdesk staff require specific, scenario-based vishing recognition training.



Enforce Procedural Controls on High-Risk Actions

MFA resets, password changes, and privilege grants must have tiered verification requirements. Policy must be explicit, trained, and enforced — not left to operator judgement.



OSINT Is an Attacker's First Tool

LinkedIn and public profiles provide sufficient context for convincing impersonation. Employees in high-value roles should understand their public digital footprint as an organisational risk.

⚠ Bottom line: The most expensive ransomware attack in recent hospitality industry history began with a phone call. The technical defences were never reached because the human controls failed first.